



Securing Azure & Entra with Code: Maester, IaC and Open-Source Security Tools.

PERTH MICROSOFT SECURITY MEETUP

—— Practitioners • Leaders • Community ——





Stephen Tulp 

APAC Principal Architect & Distinguished Technologist @ Insight



Agenda

- **Identity:** Entra Tracker and M365 Permissions
- **Network:** Azure Firewall Pipelines
- **IaC:** PSRule
- **Compliance:** Azure CIS Foundations Audit tool
- **Operations:** Maester and Lokka



Security as Code

Security as Code (SaC) means integrating automated security checks, policies, and configuration controls directly into your DevOps workflows and Infrastructure as Code (IaC) templates. Instead of treating security as a manual review phase at the end of deployment, SaC shifts security left, enabling automatic enforcement inside continuous integration and continuous deployment (CI/CD) pipelines.



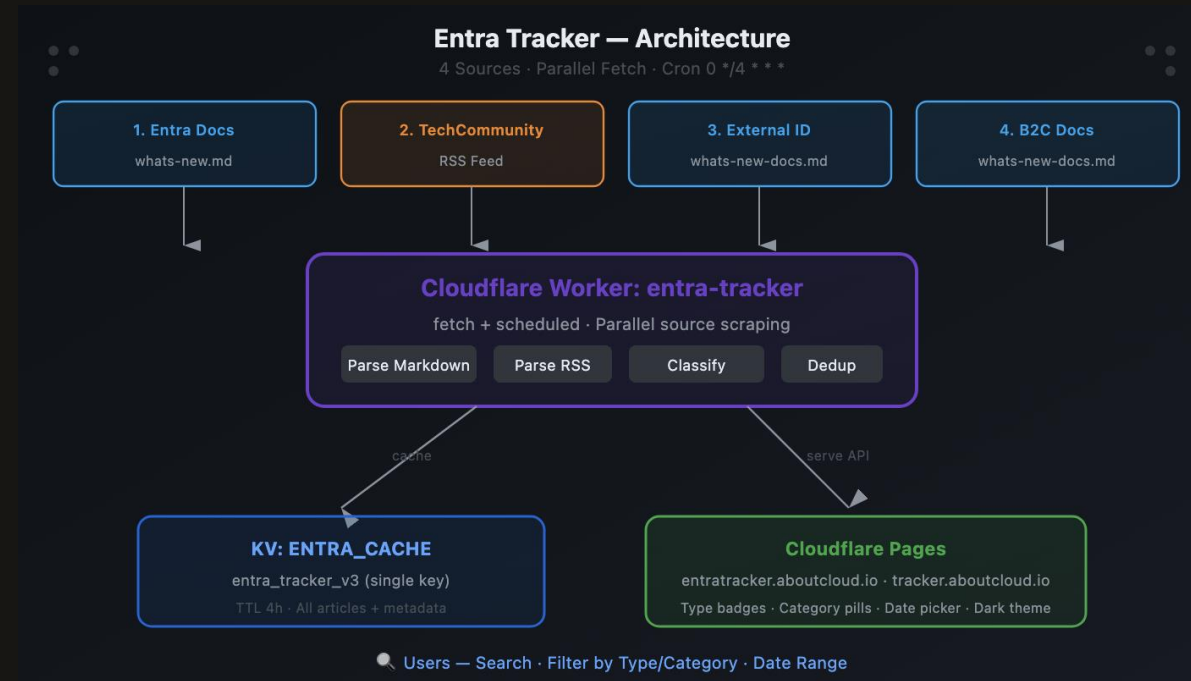
Getting Started

- Leverage the many open-source repos and IP that are available to you.
- Create a GitHub Repo and start testing these things in an isolated Azure subscription and Entra Tenant
- Utilise a DevContainer or GitHub Codespaces as your workbench, especially if you want to leverage some of the AI capabilities and IP available.
- Get across Microsoft Graph, KQL and PowerShell if you are in the Microsoft security space.



Entra Tracker – Keep up to date with Changes

“A Live tracker for Microsoft Entra ID retirements, breaking changes, preview features, and what's-new updates. Auto-updated every 4 hours from official Microsoft sources.”



<https://entratracker.aboutcloud.io/>

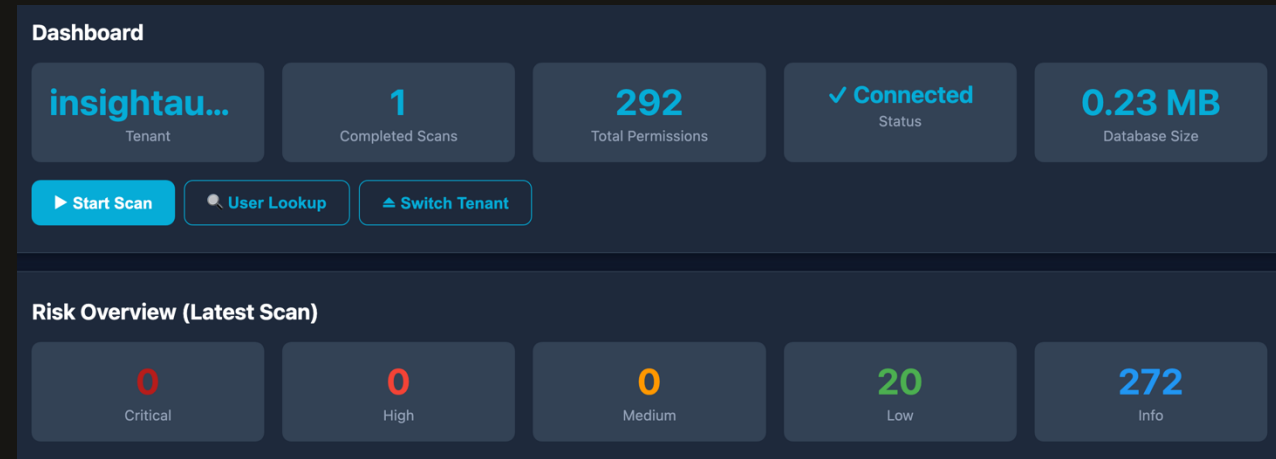
<https://github.com/arusso-aboutcloud/Entra-Tracker>



M365 Permissions

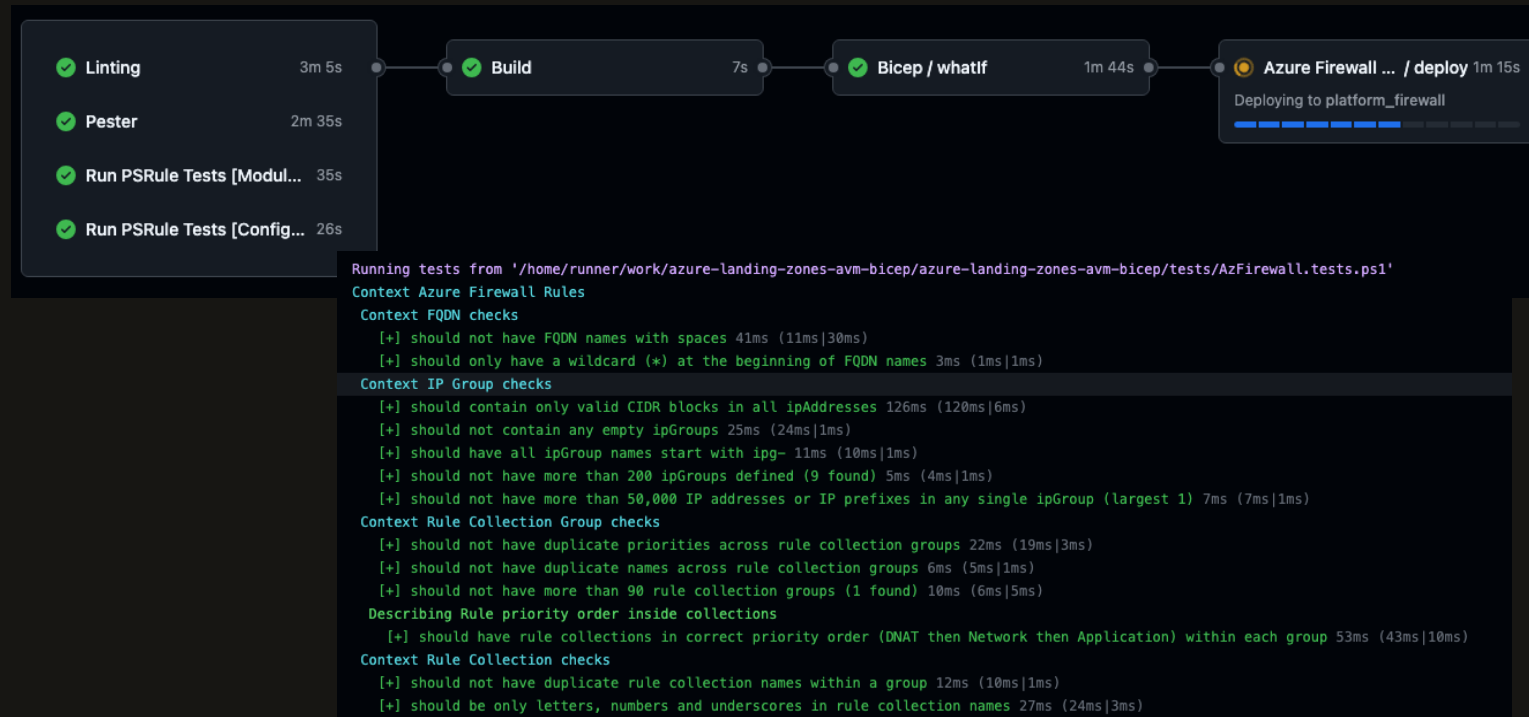
"A PowerShell module that scans and reports on permissions across SPO, EXO, Entra ID, Exchange Online, OneDrive, PBI, PP, Azure RBAC, and Azure DevOps."

- **Web UI:** opens automatically with dashboard, scan progress, results viewer
- **Export:** Export to XLSX or compliant CSV.
- **Scan Comparison:** Detect added, removed, and changed permissions between scans.
- **Cross-Platform:** Runs on Windows, macOS, Linux(PowerShell 7.4+)



Azure Firewall – CI/CD Azure Firewall Rules

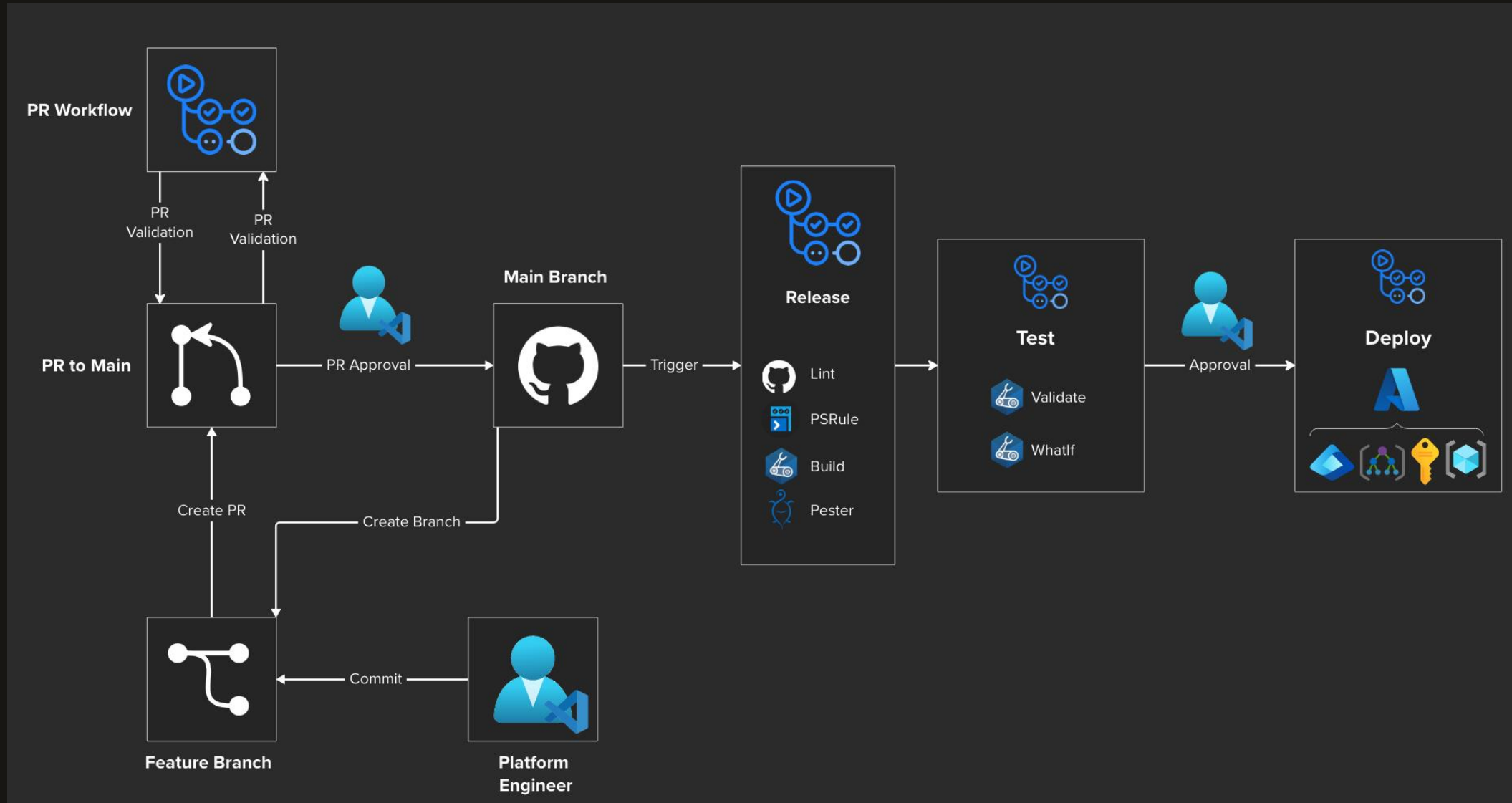
“Automated IaC and CI/CD approach to managing Azure Firewall rules at scale, leveraging Azure Bicep, GitHub Actions and Pester.”



<https://github.com/tulpy/azure-firewall>



Azure Firewall – CI/CD Azure Firewall Rules



PS Rule – Secure IaC Deployments

“PSRule is a rules engine geared towards testing Infrastructure as Code (IaC) in Azure.”

- **Reuse and Share:** Existing pre-built rules, configure, or write your own.
- **Incremental Adoption:** Baselines allow you to keep moving forward.
- **Handle Exceptions:** Keep exceptions auditable in git history.
- **Documentation:** Provides recommendations and examples instead of pass/fail.

Run PSRule Tests [Modules] summary

PSRule result summary

✓ PSRule completed with an overall result of 'Pass' with 393 rule(s) and 81 target(s) in 00:00:34.9872079.

Source

The following modules were included in analysis.

Module	Version
PSRule	v2.9.0
PSRule.Rules.Azure	v1.47.0

Analysis

Analysis did not return any failing or erroring results.

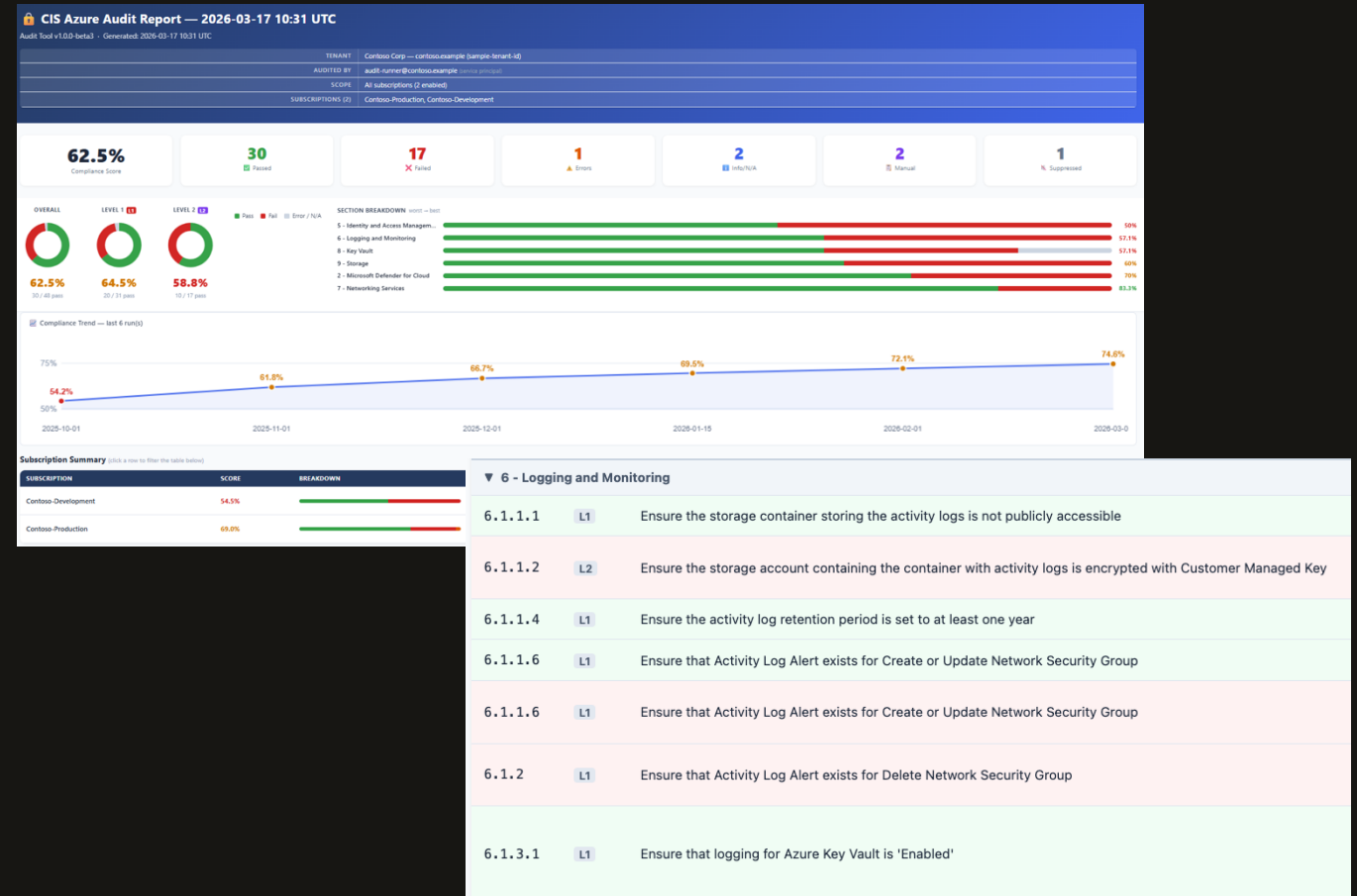
[Job summary generated at run-time](#)

```
Administrator: Windows Pow...
| - Path tags: Does not exist.
| HELP:
| - https://azure.github.io/PSRule.Rules.Azure/en/rules/Azure.Resource.UseTags/
[PASS] Azure.Resource.AllowedRegions (AZR-000167)
[PASS] Azure.VNET.Name (AZR-000268)
-> Microsoft.Compute/disks [5/6]
[PASS] Azure.Resource.UseTags (AZR-000166)
[PASS] Azure.Resource.AllowedRegions (AZR-000167)
[PASS] Azure.VM.DiskAttached (AZR-000250)
[PASS] Azure.VM.DiskSizeAlignment (AZR-000251)
[FAIL] Azure.VM.ADE (AZR-000252)
| File: 03655dca-fbbe-46b7-9acf-58391be29757.json:1:366879
| RECOMMEND:
| Consider using Azure Disk Encryption (ADE) to protect VM disks from being
| downloaded and accessed offline.
| REASON:
| - Path Properties.encryptedSettingsCollection.enabled: Does not exist.
| - Path Properties.encryptedSettingsCollection.encryptedSettings: Does not exist.
| HELP:
| - https://azure.github.io/PSRule.Rules.Azure/en/rules/Azure.VM.ADE/
```



Azure CIS Foundations Audit Tool

"Audit and Azure environment against the Azure CIS Foundation benchmark, exported to HTML or CSV."

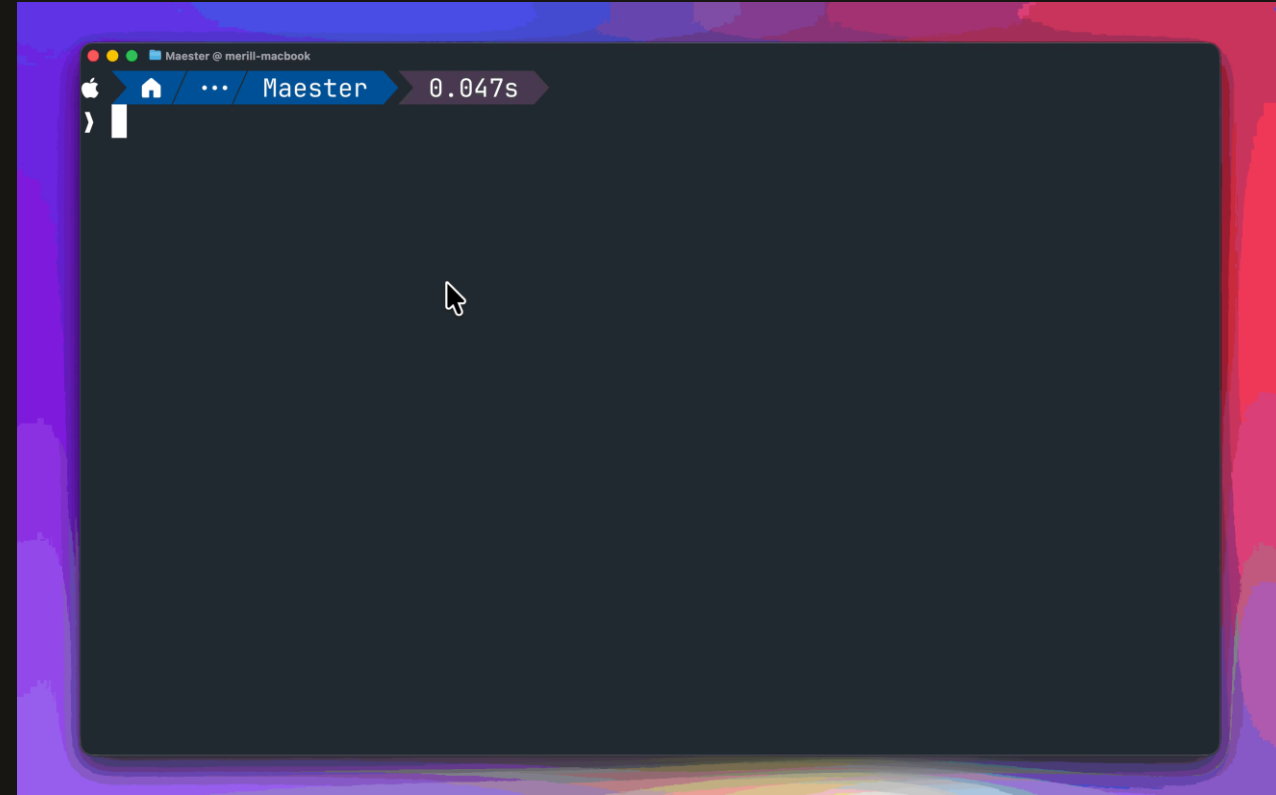


<https://github.com/vegazbabz/CIS-Azure-Benchmark-Audit-Tool>



Maester – Test Automation Framework

“Maester is a Microsoft Security test automation framework for Entra, Microsoft 365, Azure, Azure DevOps and Defender for Endpoint.”



- **Ready-made Tests:** Hundreds of curated tests covering identity, access, devices and apps.
- **Continuous Monitoring:** Schedule Maester in GitHub Actions, Azure DevOps or Azure Automation.
- **Compliance Baselines:** EIDSCA, CISA, SCuBA, CIS Microsoft 365 and ORCA
- **Configuration Guidance:** Ships with remediation steps and direct links into the Microsoft Admin portals.
- **Multi-Tenant Support:** Can be used across multiple tenants, both internal and MSP.

